

# 【中间件安全】Weblogic 安全加固规范 - 微信公众号Bypass

版权声明：本文由Bypass原创发布，转载请保留出处。欢迎关注我的个人微信公众号：Bypass--，浏览更多精彩文章。[https://blog.csdn.net/qq\\_23936389/article/details/85013924](https://blog.csdn.net/qq_23936389/article/details/85013924)

## 1. 适用情况

适用于使用Weblogic进行部署的Web网站。

## 2. 技能要求

熟悉Weblogic安装部署，熟悉Weblogic常见漏洞利用方式，并能针对站点使用Weblogic进行安全加固。

## 3. 前置条件

- 1、根据站点开放端口，进程ID，确认站点采用Weblogic进行部署；
- 2、找到Weblogic站点位置

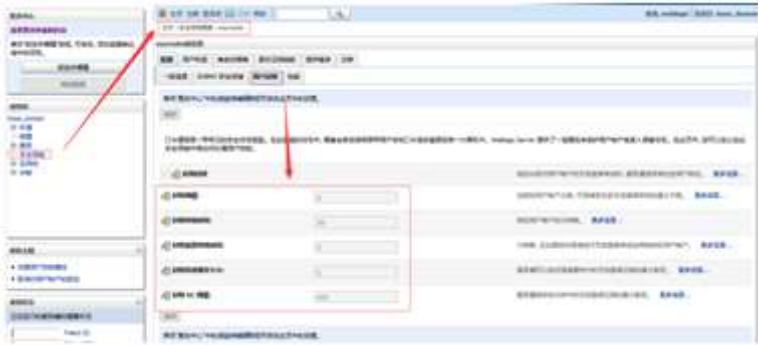
## 4. 详细操作

### 4.1 控制台用户设置

- 1、用户弱口令修改



- 2、用户账号锁定设置



3、设置密码策略

安全领域> myrealm>提供程序>口令验证> SystemPasswordValidator>提供程序特定> 配置策略



4.2 日志配置

默认情况下, HTTP 日志记录处于启用状态, 日志默认在base\_domain\servers\AdminServer\logs目录, 其中 access.log是安装在该server之上的应用的的http访问日志。

1、在Weblogic管理后台, 找到环境—[服务器](#), 然后锁定并编辑, 点击服务名称进入设置页面:



2、选择日志记录--HTTP



4.3 最佳经验实践

4.3.1 更改默认运行端口

依次点击环境>服务器>Adminservers(管理)>一般信息，更改监听端口7001为其他端口：



4.3.2 禁用Send Server Header

依次点击环境>服务器>Adminservers(管理)>协议>http

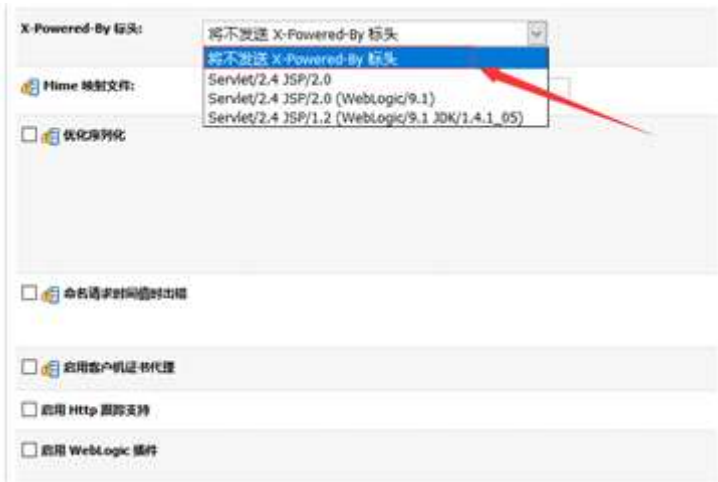
检查是否勾选Send Server header



4.3.3 禁用X-Powered-By Header

依次点击base\_domain>web应用程序，

在X-Powered-By 标头修改为 “将不发送X-Powered-By Header”



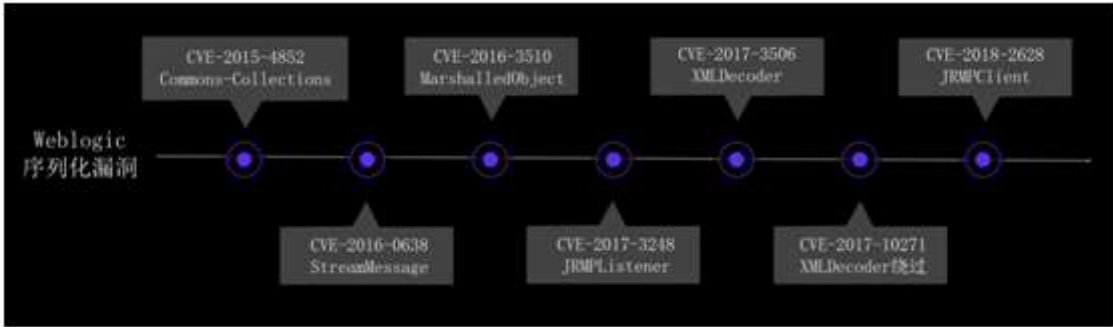
4.3.4 限制应用服务器Socket数量

依次点击环境>服务器>Adminservers(管理)>配置>优化



## 4.4 风险操作项

Weblogic历史漏洞展示:



### 4.4.1 CVE-2018-2628临时解决方案

CVE-2018-2628解决方案:

Oracle WebLogic反序列化漏洞CVE-2018-2628 官方补丁，Oracle官方已经在关键补丁更新（CPU）中修复了该漏洞，强烈建议受影响的用户尽快升级更新进行防护。<http://www.oracle.com/technetwork/security-advisory/cpujan2017-2881727.html>

临时解决方案:

可通过控制T3协议的访问来临时阻断针对该漏洞的攻击。WebLogic Server提供了名为weblogic.security.net.ConnectionFilterImpl的默认连接筛选器，此连接筛选器接受所有传入连接，可通过此连接筛选器配置规则，对t3及t3s协议进行访问控制，详细操作步骤如下：

- 1、进入Weblogic控制台，在base\_domain的配置页面中，进入“安全”选项卡页面，点击“筛选器”，进入连接筛选器配置。



2、在连接筛选器中输入：weblogic.security.net.ConnectionFilterImpl，在连接筛选器规则中输入：\* \* 7001 deny t3 t3s



3、保存后规则即可生效，无需重新启动。



#### 4.4.2 补丁更新

根据Weblogic版本到weblogic官网下载补丁包，各版本选择下载地址：

<http://www.oracle.com/technetwork/middleware/weblogic/downloads/wls-main-097127.html>

#### 4.4.3 Weblogic降权

以weblogic 12c为例，执行如下命令：

```
1. # su - root
2. # groupadd weblogic
3. # useradd -g weblogic weblogic -s /bin/bash
4. # chown -R weblogic:weblogic /tmp/wls12120
5. 然后重新启动服务
6. # su - weblogic
7. #/tmp/wls12120/user_projects/domains/mydomain/startWebLogic.sh
```

最后

欢迎关注个人**微信公众号**：Bypass--，每周原创一篇技术干货。

